

NIST SP 800-171, SPRS Scoring, and CMMC Readiness: The AI Tech Pros Field Guide

Revision 1.1.0, September 29, 2026. Plain English, zero fluff.

Prepared by AI Tech Pros, Inc. Nehemiah Harvard, CEO.

Staleness warning. This guide is current as of September 2026. Cybersecurity regulation moves: before you rely on it, confirm nothing material has changed by checking DoD announcements, the current 32 CFR Part 170, and the NIST SP 800-171 revision in force. For updates, subscribe to The Readiness Room (free): <https://thereadinessroom.substack.com>

The bottom line

CMMC Level 2 is NIST SP 800-171 Rev. 2. Same 110 requirements. No additions, no subtractions. Your SPRS score is the number contracting officers check before award. Everything else is commentary.

Where things stand right now

On July 13, 2026, the Department of Defense suspended CMMC Phase 2 (third-party C3PAO assessments) and launched a 60-day reform review. The task force report was due mid-September 2026 and had not been made public as of this writing. Only a class deviation, a DFARS rule change, or an amendment to 32 CFR Part 170 changes your obligations. None has happened yet.

What did NOT change:

- DFARS 252.204-7012. You must implement all 110 controls. Still enforced.
- DFARS 252.204-7019 / 7020. Self-assessment scores are still posted to SPRS.
- 72-hour cyber incident reporting. Still required.
- DOJ enforcement. The Department of Justice is still bringing False Claims Act cases over cybersecurity misrepresentation. Announced cyber settlements already top \$16 million across five cases, and Honeywell paid \$2.04 million to resolve allegations it failed to meet DoD cybersecurity requirements.

Translation: the third-party assessment gate is paused. The security requirements behind it are not. Contracting officers still check SPRS.

How SPRS scoring actually works

You start at 110. Every requirement you have not implemented subtracts its weighted value: 5, 3, or 1 point, based on how critical DoD considers that control. The weights are published in the NIST SP 800-171 DoD Assessment Methodology.

The weights, all 110:

5-point controls, basic requirements (23):

3.1.1, 3.1.2, 3.2.1, 3.2.2, 3.3.1, 3.4.1, 3.4.2, 3.5.1, 3.5.2, 3.6.1, 3.6.2, 3.7.2, 3.8.3, 3.9.2, 3.10.1, 3.10.2, 3.12.1, 3.12.3, 3.13.1, 3.13.2, 3.14.1, 3.14.2, 3.14.3

5-point controls, derived requirements (19):

3.1.12, 3.1.13, 3.1.16, 3.1.17, 3.1.18, 3.3.5, 3.4.5, 3.4.6, 3.4.7, 3.4.8, 3.5.10, 3.7.5, 3.8.7, 3.11.2, 3.13.5, 3.13.6, 3.13.15, 3.14.4, 3.14.6

3-point controls (14):

3.3.2, 3.7.1, 3.8.1, 3.8.2, 3.9.1, 3.11.1, 3.12.2, 3.1.5, 3.1.19, 3.7.4, 3.8.8, 3.13.8, 3.14.5, 3.14.7

1-point controls (52): all remaining derived requirements.

2 special controls, scored on degree of implementation:

- 3.5.3 (multifactor authentication): minus 5 if MFA is absent entirely, minus 3 if implemented for remote and privileged users but not all users.
- 3.13.11 (FIPS-validated encryption for CUI): minus 5 if no FIPS-validated cryptography, minus 3 if encryption is in use but not FIPS-validated.

Ceiling: 110. Floor: negative 203.

Rules that surprise people:

- A POA&M does not change your score. The score reflects what is implemented today, not what you plan to implement.
- Partial implementation scores the same as not implemented, except for the two special controls above.
- Controls marked Not Applicable subtract nothing, with documented justification.
- No System Security Plan means no score at all. The methodology assesses the SSP, so without one the assessment cannot be completed.
- Only DoD personnel see your posted score. You see your own.

The 14 families at a glance

Family	Controls	What it covers, in plain English
Access Control (3.1)	22	Who can touch what, remote access, wireless, mobile
Awareness and Training (3.2)	3	Security training, role-based training, insider threat awareness
Audit and Accountability (3.3)	9	Logging what happens, protecting the logs, reviewing them
Configuration Management (3.4)	9	Baselines, change control, least functionality
Identification and Authentication (3.5)	11	MFA, passwords, authenticator management
Incident Response (3.6)	3	IR capability, reporting, testing the plan
Maintenance (3.7)	6	Controlled maintenance, tools, remote maintenance

Family	Controls	What it covers, in plain English
Media Protection (3.8)	9	Handling, marking, storing, and destroying CUI media
Personnel Security (3.9)	2	Screening people, handling transfers and terminations
Physical Protection (3.10)	6	Locks, visitors, logs, badges
Risk Assessment (3.11)	3	Risk assessments, vulnerability scanning, fixing what you find
Security Assessment (3.12)	4	Assessing yourself, POA&Ms, the SSP
System and Communications Protection (3.13)	16	Boundaries, encryption, network architecture
System and Information Integrity (3.14)	7	Patching flaws, malware protection, monitoring

The gate nobody tells you about

A score of 88 is not enough for Conditional status. Under 32 CFR 170.21, two conditions must both hold:

1. Assessment score of 88 or higher (80 percent of 110).
2. Every open requirement on the POA&M is worth 1 point. One exception: 3.13.11 at minus 3 (encryption in use but not FIPS-validated) may be deferred.

Six requirements can never appear on a POA&M, regardless of point value: 3.1.20, 3.1.22, 3.10.3, 3.10.4, 3.10.5, and 3.12.4 (the System Security Plan).

Net effect: 63 of the 110 requirements are never deferrable. The deferrable layer is the thin set of remaining 1-point controls. POA&M items must be closed within 180 days of the Conditional status date, confirmed by a closeout assessment, or the status expires.

The score is not the constraint. The weight of what you are missing is.

The priority order

This is the Prioritize step of MAPS, and it is why a one-day sprint beats six months of guessing:

1. The never-deferrable six. If any are open, nothing else matters. Close them first.
2. Open 5-point controls. Each one closed is 5 points back on the board. Work the family with the most gaps first.
3. The encryption play. If 3.13.11 is fully open (minus 5, never deferrable), implement encryption now even before FIPS validation. That converts a disqualifying 5-point hit into a deferrable 3-point item.
4. 3-point controls. Close them in family order.
5. 1-point controls. Sequence the eligible ones into POA&Ms; close the rest outright.

DFARS clause cheat sheet

Clause	What it does
FAR 52.204-21	Basic safeguarding of FCI. The 15 requirements behind CMMC Level 1.
DFARS 252.204-7012	Safeguarding covered defense information. Requires implementing all 110 controls, 72-hour incident reporting, and flow-down to subcontractors.
DFARS 252.204-7019	Notice of assessment requirements. Requires posting your Basic self-assessment score to SPRS.
DFARS 252.204-7020	DoD assessment requirements. Allows government Medium and High assessments.
DFARS 252.204-7021	The CMMC clause. Requires certification at the specified level as a condition of award.

How we run this: MAPS

The Readiness Sprint installs this framework in your company in one day:

- Map. All 110 controls mapped to your environment. Every gap located, evidence inventoried.
- Assess. Your true SPRS score, calculated per the DoD methodology. No guesswork.
- Prioritize. Every gap sequenced by the rules above. Highest contract risk first.
- Sustain. The cadence that keeps your score current, your evidence fresh, and your POA&Ms on schedule.

You leave with the operating system, not a report.

The companion files in this repo run the system day to day: evidence-index.csv (map every control to evidence), scoring-validation-checklist.md (assess without guessing), remediation-tracker.csv (prioritize and sustain the POA&Ms), and independent-review-gate.md (the review that must pass before attestation).

Before you post to SPRS

Do not post a score to SPRS until four things are true:

1. The evidence index is complete for all 110 controls, and every Implemented control has evidence.
2. The scoring validation checklist passes.
3. The independent review gate passes, with a signed review record.
4. Management has attested to the score in writing.

Posting a score you cannot evidence is a False Claims Act risk. Announced DOJ cyber settlements already top \$16 million across five cases, and your own people can file the case and take 15 to 30 percent.

What this guide is not

This guide and the MAPS framework are an operating system, not a certification. They do not make you CMMC

certified, they do not replace a C3PAO assessment, and they are not legal advice. If you want MAPS installed in your company in one day, that is the AI Tech Pros Readiness Sprint: <https://aitechpros.ai>

What to watch

- The CMMC Reform Task Force report. Due mid-September 2026, not yet public. Direction signals from DoD leadership (continuous monitoring favored over point-in-time assessment, operational technology risks, CUI marking discipline) are statements, not policy.
 - NIST SP 800-171 Rev. 3. CMMC still references Rev. 2. Implement against Rev. 2 and monitor DoD announcements.
 - Your SPRS score. Regardless of what the task force recommends, the scoreboard is live today.
-

Sources

- NIST SP 800-171 Rev. 2, DoD Assessment Methodology (scoring weights and methodology)
- 32 CFR Part 170, including 170.21 (POA&M and Conditional status) and 170.24 (scoring methodology)
- DFARS 252.204-7012, 252.204-7019, 252.204-7020, 252.204-7021; FAR 52.204-21
- DoD CIO memorandum, July 13, 2026 (Phase 2 suspension and reform review)

MAPS (Map, Assess, Prioritize, Sustain) by AI Tech Pros, Inc., Augusta, GA. <https://aitechpros.ai> | Framework updates: The Readiness Room, <https://thereadinessroom.substack.com> (free) | Revision 1.1.0, September 29, 2026. MIT License.